

Post-Mortem: What Happened Between Samurai Wallet and Me

How a wallet that adopted my privacy framework turned technical disagreement into a reputational war - and what I got wrong too

After law enforcement seized Samurai Wallet's servers, William Hill - TDevD - messaged an associate: "Not good." Then he named the thing that worried him: "I'm not thinking so much about Whirlpool as I am about the wallet backends (xpubs)."^[xpub-seizure]

An extended public key cannot spend a user's bitcoin, but it can reveal the addresses derived from a wallet and follow their history. For years, I had argued that Samurai's default backend created exactly this point of failure. Hill's message showed that he understood why the seizure of that backend mattered.

at 6; Hill Subm. at 17, 19). But Rodriguez and Hill's public and private statements and their Samourai marketing materials unmistakably reveal that, even if general user privacy generally was *one of* the overarching features of the platform, soliciting criminals to use Samourai was likewise a feature, and one that the defendants expressly touted.¹⁸

With respect to Hill, his instant attempts to disavow or downplay his public statements is no more than a transparent bid for leniency at sentencing. Hill—in an about-face from his yearslong public persona—brushes off his prior public and private statements, claiming they were simply “guerilla” marketing and “must be understood in the context of his autism.”¹⁹ (Hill Subm. at 36; Hill Letter at 106). Hill's disavowals ring hollow. As explained above, his contemporaneous statements are not ambiguous and self-evidently promoted Samourai as a tool for criminals. Hill's statements were made over a period of years, in multiple public and private forums, and were consistent in tone and content—they demonstrate that Hill meant what he said, and these statements were not merely marketing hyperbole. Indeed the argument that this could have been the purpose of Hill's *private* communications with colleagues and associates strains credulity.

X PUB information with past, present and future Whirlpool transactions to associate input and output addresses belonging to its mobile-only users. After law enforcement seized Samourai's servers, Hill messaged an associate, “Not good,” and noted “I'm not thinking so much about Whirlpool as I am about the wallet backends (xpubs).” (PSR ¶¶ 19-20).

¹⁸ Rodriguez and Hill do not dispute the substance of their statements or marketing materials. They only dispute the inferences that can be drawn from them regarding Rodriguez's and Hill's intent to solicit criminals as Samourai users.

¹⁹ Hill also claims that his autism “reduces his moral culpability.” (Hill Subm. at 28). The Government acknowledges that the Court should consider Hill's autism as relevant to the “history and characteristics of the defendant,” but the defendant has not shown or even attempted to show that his autism precluded him from understanding right from wrong, and the Court should reject any suggestion that the defendant's autism “reduces his moral culpability.”

The government's sentencing memorandum records Hill's post-seizure message: “Not good,” followed by his concern about “the wallet backends (xpubs).” [Open the archived filing.](#)

The seizure did not create the xpub problem. It exposed the consequences of a design choice that had been there from the start.

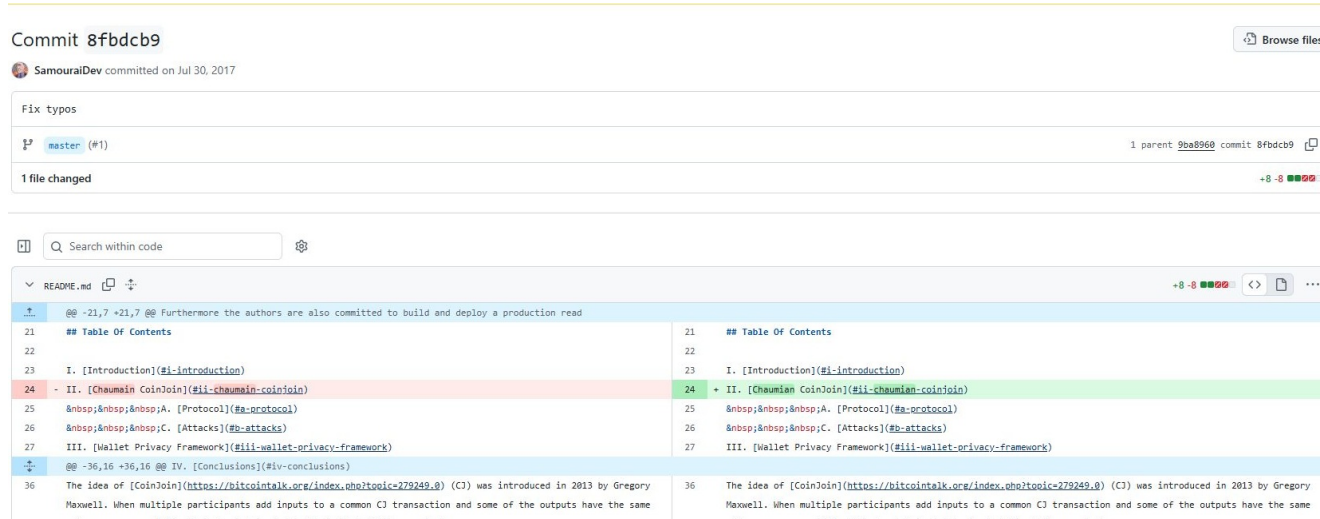
This is a post-mortem, not a victory lap. A prison sentence cannot settle a protocol dispute, and an indictment cannot make every allegation true. I will distinguish what the public record establishes, what I infer from it, and what I remember but cannot independently prove.

To understand what was sitting on that server - and why I had spent years shouting about it - we have to go back to a README file in July 2017, before the feud began.

How ZeroLink actually began

I wanted Samourai to succeed in implementing ZeroLink. I wanted more wallets to implement serious Bitcoin privacy, and I wanted ZeroLink to become useful software rather than another specification admired by a small circle and ignored by everyone else.

I created ZeroLink. The [repository](#) makes the chronology clear. I opened it on July 28, 2017. Before Samourai made a single commit, I had made 19 and written a 184-line, 2,883-word document containing the framework’s core architecture. Samourai’s first commit arrived two days later. Its title was [“Fix typos”](#). It did exactly that.



SamouraiDev’s first ZeroLink commit, July 30, 2017: “Fix typos.” [Open the commit](#).

At the August 14 publication snapshot, Git blame attributes 6,126 of the document’s 6,627 words to me and 242 to Bill/TDevD. Their only sizeable technical addition concerned BIP47 and stealth addresses. I did not understand what problem it solved or why it belonged in ZeroLink. Instead of challenging it, I assumed that I was missing something and accepted it out of politeness. Two days later I clarified that BIP47 was not part of the protocol, and I removed the section in 2019. The rest of their work was overwhelmingly light editing. The complete commit and line-churn audit is preserved in the source note.^[zerolink]

I had also put TDevD in the Authors section before the BIP47 proposal was committed. Both decisions came from the same reflex: they spoke with confidence, I assumed that any confusion was mine, and I tried to be generous. This foreshadowed a later pattern. Their confidence made me doubt my own judgment, while my politeness was used to support a claim of authorship that the repository does not support.

By 2022 - three years after I had publicly challenged the joint-creation claim, with the Git history still open for anyone to inspect - Samourai was still repeating it.^[7]

I regard those later repetitions as a lie. “Collaboration” can be innocent shorthand while nobody has disputed it. It stops being innocent after the primary record is placed in front of you and you keep telling the version that promotes you from reviewer and prospective implementer to co-creator. The false version gave Samourai ownership of the intellectual foundation it had adopted and made my later objections sound like jealousy over something we had supposedly invented together.

Our contact was limited. We barely spoke, and I was never part of Samourai. I had created ZeroLink; Samourai said it intended to implement it. Brian “Shinobi” Trollz, who observed the dispute at the time,

later recalled a specific turning point. I asked for a week to consider whether coordinators could be run altruistically. During that week, he said, Samourai’s posture toward me [shifted into mockery](#). By April 2019, I had recorded that they were no longer interested or responsive and that I had [continued independently](#). People can disagree about why that limited contact ended. The authorship record is not a matter of recollection.

The authorship dispute mattered to me. The architectural difference mattered to users.

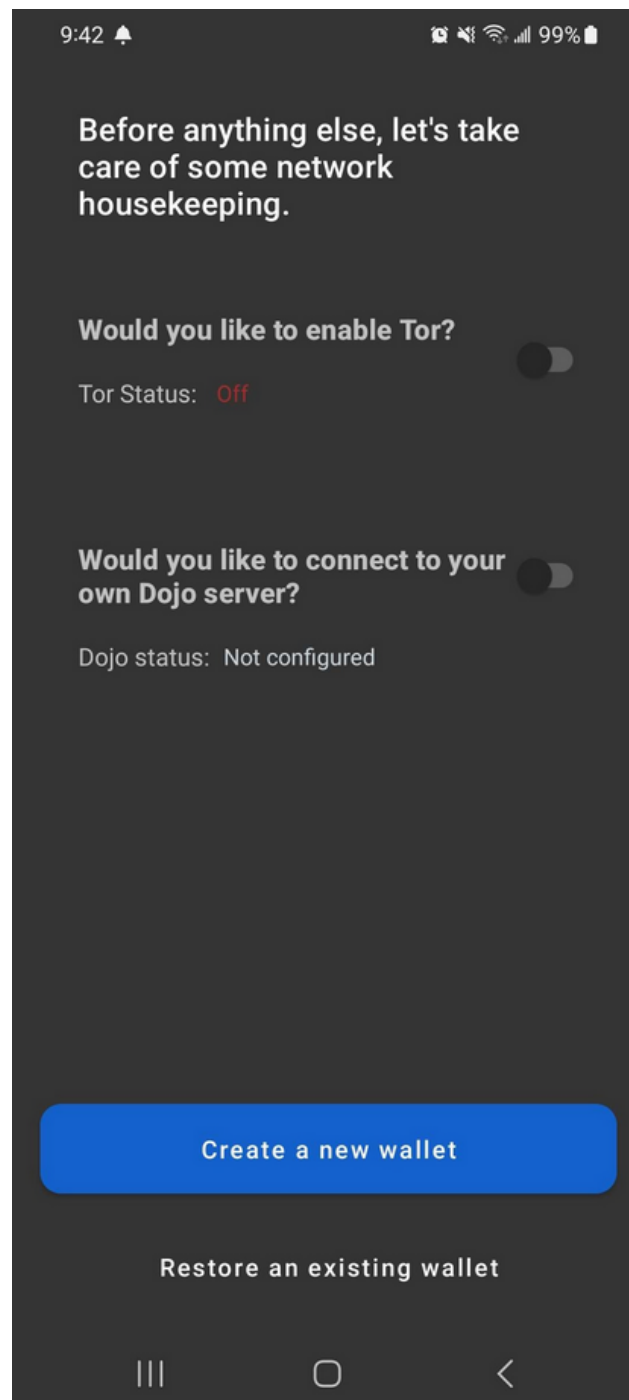
The central privacy difference

Wasabi and Samourai did not merely choose two equally respectable collections of privacy tradeoffs.

Wasabi’s default architecture was built to deny its own operator the wallet graph. The backend distributed block filters; clients checked addresses locally; wallet traffic went through Tor; and blinded CoinJoin credentials prevented the coordinator from linking a registered input to its output. A user did not need to operate a personal server to hide addresses and transaction history from us. Privacy from the service operator was the default.^[operator]

Samourai’s default client did the opposite at the point that mattered most: it sent extended public keys to Samourai’s hosted backend. Whoever holds an xpub can derive its associated addresses and follow their transactions. Samourai’s own Dojo documentation disclosed the consequence indirectly. Running MyDojo improved privacy by “completely bypassing” the default hosted servers, while its Tracker recorded registered xpubs and addresses.^[operator]

Tor support existed, but it was not enabled by default. Samourai’s signed source allowed a user to create a wallet while Tor remained off, treated the Tor preference as `false` unless the user enabled it, and used the ordinary network path for xpub requests when Tor was disabled. A screenshot preserved in an April 2023 issue on Samourai’s own GitLab showed the wallet-creation screen with both Tor off and Dojo unconfigured. The user could continue by pressing “Create a new wallet.” That default exposed the user’s IP address to Samourai’s hosted service while the same service received the wallet’s xpubs.^[tor-default]



The wallet-creation screen attached to Samurai's own issue tracker: Tor off, Dojo not configured, and "Create a new wallet" still available. [Open the archived issue](#).

The issue was titled "Important privacy features are disabled by default." It proposed enabling Tor and Dojo by default or, at minimum, warning users what the off settings exposed. A Samurai project owner replied that the proposal would not be merged, called the report "concern trolling," issued a "first and final warning," and immediately closed the issue.^[tor-default] The privacy problem was reported on their own development platform. Their answer was to reject the change and threaten the person who reported it.

Sentinel, Samurai's watch-only app, made the same architecture even easier to see. A watch-only wallet legitimately needs an xpub, and Sentinel correctly said that it could not spend the user's coins. But the privacy question was what happened to the xpub after the user imported it. In August 2017, Samurai committed a change titled "move XPUB multiaddr to Samurai API." From then on, Sentinel sent each

tracked xpub to Samourai’s hosted backend. It did so for more than two years before Tor routing was added; when Tor arrived, its preference defaulted to off. The last pre-seizure source still let a user choose Samourai’s server, answer “No” to “Connect through Tor?”, and then posted imported xpubs to that server.^[sentinel] Sentinel did not give Samourai the power to steal the coins. It gave Samourai the power to map them. When used with the hosted server, collecting wallet maps was not incidental telemetry. It was how the product worked.

The screenshot shows a GitHub commit page for the repository 'Samourai-Wallet / sentinel-android'. The commit is titled 'APIFactory: move XPUB multiaddr to Samourai API' and was made by 'SamouraiDev' on August 12, 2017. The commit message is 'APIFactory: move XPUB multiaddr to Samourai API'. The diff shows changes to the file 'APIFactory.java' in the 'api' directory. The diff highlights a change in the 'getXPUB' method where the 'multiaddr' parameter is updated from 'Web.BLOCKCHAIN_DOMAIN' to 'Web.SAMOURAI_API2'.

The Sentinel commit that moved XPUB multiaddr queries to Samourai’s API. [Open the commit.](#)

Dojo did not change what the default client disclosed. Most users of a mobile wallet will use the default, and even people who ran Dojo entered Whirlpool rounds alongside default-server users. If the common operator could identify or eliminate the outputs belonging to wallets it already knew, the effective anonymity set shrank for everyone; in some rounds, the remaining participants could be exposed by exclusion.^[1]

This was not a cosmetic difference between mobile convenience and desktop purity. It was the difference between a system designed so the operator could not know and a system that asked users to trust the operator not to use what it knew.

Wasabi was not perfect against every imaginable adversary. No honest system built on Bitcoin, Tor, fallible software, and human behavior can promise perfection. But against the service operator - the adversary at the center of this dispute - Wasabi placed cryptography and local processing between the user and us. Samourai relied on trust in its operator.

That was the first central hypocrisy. Samourai preached resistance to third-party surveillance while ordinary users entrusted it with a durable view of their wallets. When developers pointed out the contradiction, the honest response would have been simple: our default server receives your xpub; if that threat matters to you, run Dojo. Instead, Samourai attacked the people who explained the trust assumption.

Sockpuppets and attacks on critics

My first *SamuraiLeaks* investigation began with a suspicion: one of Samurai’s developers appeared to be promoting the project and attacking its critics through an identity presented as independent.

In April 2019, I published [the evidence that “foneBTC” and “fone-btc” were TDevD/William Hill’s sockpuppet accounts](#). The investigation is the proof. Its concluding exhibits are preserved below so the record does not depend on Medium remaining online.

Evidence gallery: View the sockpuppet investigation’s concluding exhibits

But he is. He has the exact same technical qualifications as TDev.
Coincidence?

Nail In The Coffin

fone-btc’s previous project was android.bitcoinalerts[0,1,2,3, 4]



The investigation connects fone-btc’s earlier Android project to Soft Machines SARL.

This app was created by the company Soft Machines SARL.



The co-founder of Samourai is the same as the founder of Soft Machines SARL was back then.[\[0](#), [1](#), [2](#), [3\]](#)

Get nopara73's stories in your inbox

Join Medium for free to get updates from this writer.

Enter your email

Subscribe

☒ Remember me for faster sign in

This is conclusive evidence that fone-btc and TDevD are the same person.

The conclusion and the final Soft Machines exhibit. [Read the full investigation.](#)

But the moral question does not turn on whether Bitcoin developers use pseudonyms. Pseudonyms are normal here. The problem is hidden affiliation used to manufacture consensus: one participant appearing to be several, promotion made to look organic, and an interested party presenting himself as a neutral observer. In a field where few users can audit every cryptographic claim themselves, reputation becomes part of the security model. Astroturfing corrupts that model.

I did not begin by publishing. I tried private conversation. I sought a mediator. I offered to stop discussing Samourai if the attacks stopped. I published when it became clear to me that silence would be treated not as de-escalation, but as permission.

Other developers then began describing the same experience.

Gregory Maxwell said architectural criticism was answered with harassment and accusations rather than a technical response. Nicolas Dorier reported the same reaction after pointing out that the default backend received users' extended public keys. Their comments remain in the [original discussion](#), including [Dorier's account](#). Luke Dashjr said that disclosing an RPC-password exposure in a setup guide brought an accusation that he ran a criminal protection racket; his own qualification - that local networking or a VPN could limit the exposure - remains [in the thread](#). I gathered those and similar accounts in [*SamouraiLeaks Part 2*](#).

Evidence gallery: View Gregory Maxwell's contemporaneous account

Greg Maxwell

Bitcoin Core Developer, Co-Founder of Blockstream

Context. Maxwell raised concerns about Samourai a few times in the past, most notably about that they advertise themselves as a privacy wallet, while they send back all their users' addresses to their backend server (formerly to Blockchain.info's servers.)

[-] nullc 61 points 9 months ago*

Regretfully I have to agree.

I have seen far too much outright dishonest and extremely incompetent behaviour from Samourai to ever trust it myself.

Samourai has very poor privacy while bragging about having good privacy: It sends your addresses all back to their server. Their "trusted node" mode doesn't change this, it just exposes your Bitcoin node to attacks completely needlessly. (Needlessly because they only use it to relay transactions, which they could do via the public P2P ports of any node, and because since they've already sent your addresses back to their server sending your transactions via something else doesn't increase your privacy.)

If you want strong privacy then as a start you need to run a full node (and use either Bitcoin Core wallet, or run your own electrum server), preferably via tor.

I don't doubt that they want and intend to eventually have good privacy but it seems that they're just unable to stop lying about it, even after previously being caught.

[permalink](#) [embed](#) [save](#) [parent](#) [give award](#)

[-] nullc [F] 36 points 2 months ago

IIRC Greg Maxwell criticized some practice of Samourai wallet, too.

And I paid for it too-- doing so resulted in an immediate campaign of harassment and bonkers accusations.

I feel extremely uncomfortable about Samourai. They have been consistently misleading about their privacy properties, have many purely pre-textual features, aggressively respond to any criticism with attacks, and appear to use astroturfing (though it can be hard to tell where the astroturfing ends and the enthusiastic users begin)...

Everything has its limits and shortcomings, but being frank about them and responding in a welcoming way and discussing trade-offs counts for a lot.

Maxwell's privacy warning and his account of the response, preserved in [SamouraiLeaks Part 2](#).

These people were not Wasabi employees forming a defensive wall around me. They disagreed with one another, and some criticized Wasabi too. What connected them was not allegiance to my software. It was the experience of raising a technical objection and watching the discussion pivot toward their motives, status, or character.

Chris Belcher later described substantive BIP47 objections being answered by [smears against the people raising them](#). ZmnSCPxj said Samourai had misrepresented his technical comments and again emphasized the privacy cost of the default server.^[2] A JoinMarket contributor acknowledged that individual criticisms on both sides could be valid while identifying Samourai's counterattacks as the reason productive discussion became so difficult.^[3]

The effect was to change the subject from whether a technical claim was true to whether the person making it was credible or acceptable.

Accuse loudly, qualify quietly

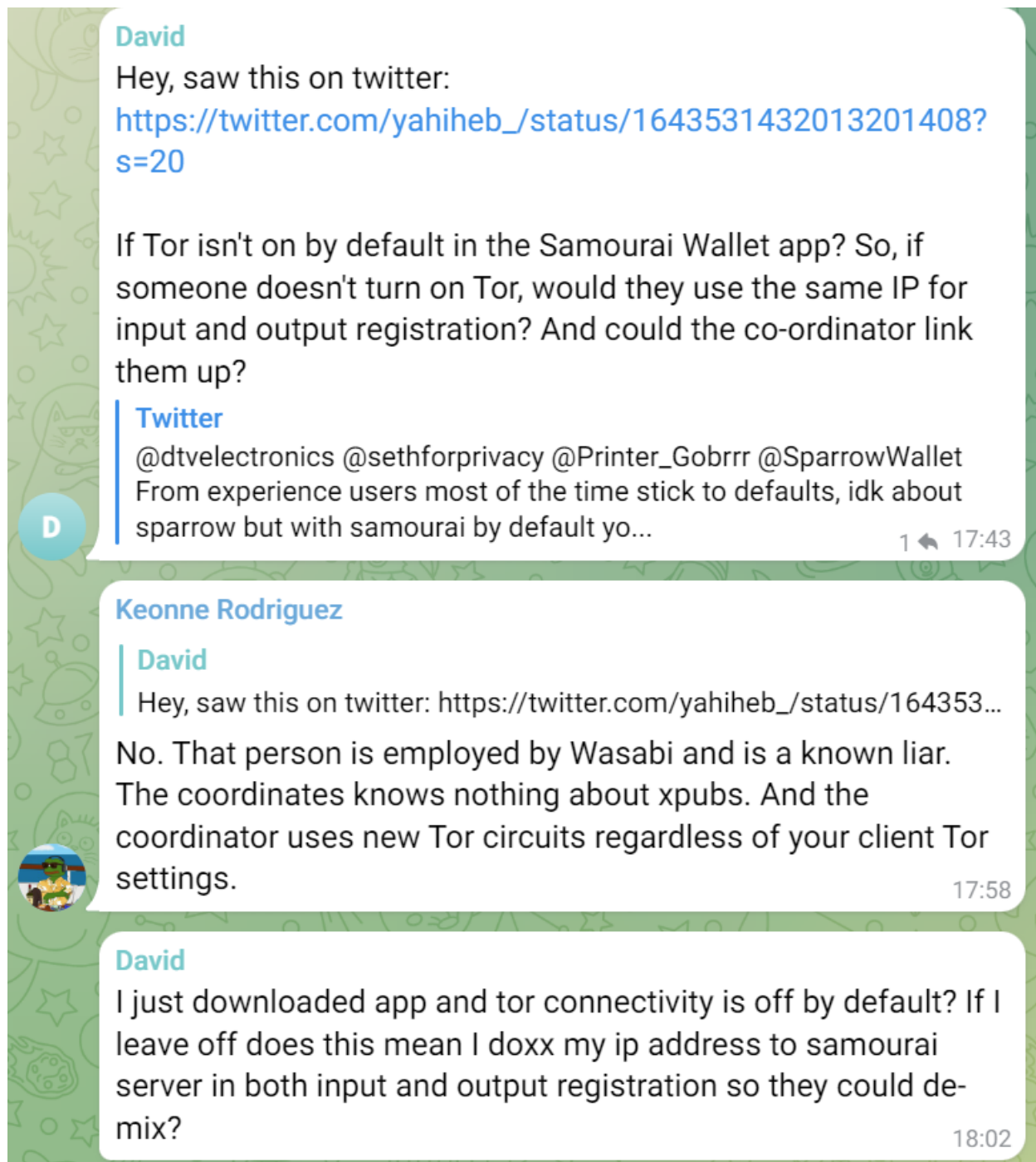
After enough repetitions, the sequence became predictable: start with something real - an uncertainty, a compromise, or a bug - then attach the most damaging interpretation available and promote it until it becomes the headline. When contrary evidence arrives, place the qualification where fewer people will see it: inside a reply, outside a screenshot, or silently inside a later code change.

The claim that I had admitted Wasabi supplied its own liquidity followed this pattern. I had made no such admission. The journalist responsible for the report [corrected the characterization](#), but the correction never travelled as far as the accusation. Another observer documented how Samurai's presentation [excluded my correction and contrary replies](#).

A cropped account can be misleading even when every visible fragment is genuine, because the omitted context changes its meaning.

The same technique appeared elsewhere. In 2023, Samurai circulated criticism from Matt Corallo while [omitting his concluding post](#). BlockDigest documented a smaller but revealing PayNym episode: a question about short-name mappings drew insults and brigading, and the issue was later patched without the public acknowledgment that would have turned a quarrel into routine engineering.^[4]

The Tor identity dispute provides another example. In April 2023, a user asked whether Whirlpool changed Tor circuits between input registration and output registration. Keonne Rodriguez answered categorically that it did and dismissed the questioner as a known liar.^[5] In March 2024, the Whirlpool client added an explicit [`changeIdentity\(\)` call before output registration](#). The code comment explained that the new identity was used to unlink the output from the input.



April 2023: Rodriguez answered that the coordinator used new Tor circuits regardless of the client's Tor settings and called the questioner a liar.

Comments 0

March 2024: the client added `changeIdentity()` immediately before output registration, with the comment “use new identity to unlink from input.” [Open the commit](#).

Evidence gallery: View the commit header

Commit fbee9e8

zeroleak committed on Mar 30, 2024

fix: change Tor identity on REGISTER_OUTPUT

1 parent b3e4bb1 commit fbee9e8

2 files changed

diff --git a/pom.xml b/pom.xml

14 14 <dependency>

15 15 <groupId>io.samourai.code.whirlpool</groupId>

16 16 <artifactId>whirlpool-protocol</artifactId>

17 - <version>1.0.1</version>

17 + <version>1.0.2</version>

18 18 </dependency>

The commit does not prove that every earlier Whirlpool round was deanonymized, and it does not prove exploitation. It does show why categorical denials and personal abuse are poor substitutes for a precise answer. The defensible response in 2023 was to explain what the client did, what had been verified, and what remained uncertain. Instead, the answer was certainty plus an insult, followed later by a code change.

This habit did more than hurt people. It taught users to read every disclosure as an attack by one tribe on another. It taught developers to calculate the social cost of reporting a problem. Eventually even small bugs became hard to discuss, because asking the question meant volunteering to become the story.^[4]

Samurai did not need to break Wasabi to damage it. It needed accusations that looked like security research.

The OXT “critical vulnerability” that failed its own test

In August 2020, the Samurai-affiliated OXT Research announced two supposed Wasabi vulnerabilities, rated them High/Critical, claimed they could cancel the privacy gained from earlier mixes, and gave us forty-eight hours to publish a warning on their terms. The full report contained a fatal premise: the attacker had to know the composition of the target’s wallet at a chosen point in time and know events affecting the wallet’s participation in later rounds. That was not a minor condition. It supplied the wallet membership that the alleged attack was supposed to uncover.^[6]

In reviewing the code of both the Wasabi Wallet client and the Wasabi coinjoin coordinator looking for such idiosyncrasies we identified the first vulnerability.

II. VULNERABILITY #1

Review of the Wasabi Wallet code base led us to the conclusion that there is no randomness introduced by the client or by the coordinator during the selection of TXOs (transaction outputs) that will participate in a given mix.

Within the code of the Wasabi Wallet client, the unique random factor that we were able to find is related to the switch between "lazy mode"/"non lazy mode" [1] but this mechanism provides only a weak protection considering that it only triggers if the selection of a single TXO or of a low number of TXOs has previously failed.

This lack of strong randomness consistently introduced by the client and/or the coordinator means that the system acts as a deterministic automaton.

For instance, the Wasabi Wallet client can be modelled as an automaton composed of:

(A) Table of Instructions that is the set of coin selection rules mainly defined in `ClientState.GetRegistrableCoinsNoLock()`.

(B) State Register storing the set of TXOs controlled by the wallet

(C) Tape composed of cells storing events related to the mixing process ("input registration of round N starts", "input registration of round N ends", "confirmation of transaction associated to round N", etc...)

2.1 – Consequences

The main consequence of this lack of strong endogenous randomness is that an observer having knowledge of events related to the mixing process and of the composition of the targeted wallet at a given step N , is able to predict which TXOs of the wallet will be selected for each round of mixing after step N , hence cancelling the benefits of the previous mixes.

Specifically, this means an attacker is able to use the coin selection algorithm to isolate remixed TXOs based on the coin selection rules. As a result, the anonset of the previous mix(es) does not contribute to the actual anonset.

Let us illustrate an example scenario of a typical coinjoin transaction with an additional coinjoin transaction after the preceding one, which is commonly referred to as a "remix".

Remixing is widely recommend as a best practice and users of most coinjoin platforms are encouraged to remix their outputs for an increase in the overall anonymity set of the remixed outputs and increase "distance" between their entrance into the mixer and their current TXO(s).

The flow of a typical coinjoin with a remix is as follows:

1. **round_N** generates a 0.1 mixed output **A**
2. output **A** remixed by **round_N+1** into txo **B**

OXT's own statement of the premise: the observer already has "knowledge of events related to the mixing process" and "of the composition of the targeted wallet." [Open the archived report.](#)

OXT avoided that problem in its demonstration by controlling both sides. Its target, "Alice," received one known 0.4 BTC coin. Its observer, "Eve," already knew which funds belonged to Alice and ran a modified Wasabi client that logged round events. Given the wallet's exact starting state, the public coin-selection code could sometimes predict which of Alice's coins the client would offer next. That showed that known software can behave predictably when the observer is handed its private starting state. It did not show how an outside observer could discover an unknown wallet's contents, identify an unknown mixed output as the target's, or recover an input-to-output link hidden by the protocol.^[6]

Even in that constructed test, the predictions did not simply work. The report recorded expected coins failing to enter rounds because of confirmation state, failed rounds, and coordinator behavior. OXT called

these deviations “exogenous randomness.” Its second “vulnerability” was a proposed use of change-output “beacons and checkpoints” to notice when the first prediction had failed and investigate why. The report’s reduced “adjusted anonsets” were values produced by OXT’s own model. They were not identities uncovered, owners identified, or blinded input-output links recovered.^[6]

Evidence gallery: View the report’s test design, admitted randomness, and severity claim

We would normally expect the anonymity set of re-mixed outputs to follow this formula:

EXPECTED REMIX ANONYMITY SET

$$\text{anonset}(B) = \text{anonset}(A) - 1 + \text{anonset}(\text{round}_{N+1})$$

Instead, deploying this vulnerability may result in a reduced anonset, and in some cases, drastically reduced.

ACTUAL REMIX ANONYMITY SET

$$\text{anonset}(B) = \text{anonset}(\text{round}_{N+1})$$

A second consequence of this first vulnerability is that anonymity sets of TXOs that weren’t selected for a given round may also be decreased when applied to other wallets participating in the same round (process of elimination).

For example, if we know that

1. *mixed output A is controlled by the target wallet and created by **round_M***
2. *mixed output A wasn’t selected for **round_N***
3. *TXO B also created by **round_M** and with the same denomination as A, was selected as an input of **round_N***

With this knowledge we can infer that **B** isn’t controlled by the target wallet. This inference allows for a decrease of the anonset of both **A** and **B**.

The lack of consistent randomness introduced in the coin selection process negates the privacy gained by previous mixes, reducing the actual privacy to that of the most recent mix.

2.2 – The role of exogenous randomness

When we think about randomness we do so in two ways. Endogenous randomness can be thought of simply as having an origin that is inherent to the system. On the other hand, exogenous randomness has its source outside of the system.

So far we have determined that there is no endogenous randomness present in the Wasabi Wallet coin selection algorithm, however we have still excluded the case of exogenous randomness that may decrease the reliability of results provided by an attack based on this first vulnerability.

It’s important to reiterate that exogenous randomness may have different sources. Thus, we’re going to use the following typology of randomness.

TABLE 1 – TYPOLOGY OF EXOGENOUS RANDOMNESS

Type A	Randomness introduced by the user and for which the attacker has no prior knowledge.
	(e.g.: new funds unknown to the attacker are enqueued, user temporarily stops her client and resumes the mixing later, custom target anonset value set by the user, etc...).
Type B	Randomness introduced by events independent from the user.
	(e.g.: unconfirmed TXOs are rejected by the coordinator, connection failure, etc...).

The report’s own category of “exogenous randomness,” which could decrease the reliability of its predictions.

OXT Research analysts were able to confirm the “Beacon and Checkpoints” approach during testing. In one case, there was an expectation that a toxic change output would be mixed after the first two rounds of mixing, but after a few hours, mixing still hadn’t occurred.

After further analysis, it appeared that this TXO was repeatedly rejected by the coordinator because it was unconfirmed (like others TXOs controlled by the wallet).

Mixing resumed as expected after the transactions associated to the first two rounds were confirmed a few hours later.

This second vulnerability can be used by both types of attackers but we suspect that it’s especially effective when used by (Type A) Attackers in order to mitigate the effect of Type A randomness.

IV. TESTING IN THE WILD

In early August 2020, a series of tests were completed that allowed OXT Research analysts to confirm that the coin selection algorithm implemented by the Wasabi Wallet client is indeed deterministic and that inputs selected for a given round could be predicted.

4.1 – Summary

From our observations, the main source of exogenous randomness during these tests seemed related to temporary scalability issues encountered by the

coordinator and leading to TXOs failing to participate to mix rounds (see: PR: 4133[2], 4134[3], 4135[4], 4136[5], 4137[6]).

Technical issues like these ones make the interpretation of results more challenging for the (Type B) Attacker. However, these types of issues do not affect the (Type A) Attacker. For example: a failure during a registration phase or during the signing phase is part of information available internally available to the Wasabi Coordinator software.

Moreover, as we can expect that issues like these get fixed soon after being reported, this de facto decreases the randomness experienced by (Type B) Attackers.

4.2 – Principle of the test

We simulated 2 actors for this test of the attack.

TABLE 3 – TEST ACTORS

Alice	Simulates the Wasabi user targeted by the attack.
	Runs an unmodified Wasabi client.
	Sends 0.4 BTC (single UTXO) to her Wasabi Wallet and enqueues this UTXO for mixing with a target anonset target of 120.
Eve	Eve simulates an attacker tracking the funds controlled by Alice and leading to Wasabi mixes.
	She acts as a "low-level" (Type B) attacker.
	She eavesdrops the Wasabi coordinator

The controlled test: Alice receives a single known 0.4 BTC input, while Eve tracks Alice’s funds and runs a modified client that logs round details.

- ◆ [3de0:45]: Adjusted anonset is 53 instead of expected anonset of 142.

4.4 – Illustrating the attack

A supplemental diagram illustrating the contents of the Simulated Memory of Deterministic Automaton spreadsheet is attached to this report [Fig 1].

The diagram illustrates the ordered timeline of the Wasabi coinjoin network as observed by Eve (green underlined text). The diagram is ordered sequentially from top to bottom based on Eve's observed timeline.

Alice's TXOs are sorted into two buckets at each event. The left bucket represents Alice's TXO waiting list (coins available for registration to the next mix round).

The TXOs in the left bucket are ordered from top to bottom in the order specified by the deterministic coin selection algorithm. In the context of this test the deterministic coins selection algorithm can be reduced to the following heuristic:

DETERMINISTIC SELECTION HEURISTIC

"Select the first available TXO covering the required funds with TXOs sorted by confirmation status, increasing anonset and decreasing amount"

The details of why a TXO is not registered for a mix are included above the left bucket. The first

sorted TXO meeting the coin mixing requirements is selected by algorithm and placed in the right bucket for mix registration.

Eve is able to marry her observed timeline, knowledge of Alice's wallet state at a given point in time (TXO and mixed output sizing), and the deterministic coin selection algorithm to predict the remixing of Alice's TXOs and exploit the attack.

V. SEVERITY

In our opinion, these vulnerabilities should be considered as **High/Critical**.

In the case of a mixed output being remixed, these vulnerabilities break the ZeroLink guarantee for the previous mix and cancel the benefits provided by the previous mix.

These vulnerabilities break the global guarantees provided to users by the mixer.

An effective attack against the user of a mixer doesn't require the de-anonymization of all user outputs. De-anonymizing or significantly reducing the anonset of a single TXO is often enough to advance an attack.

5.1 – Low Liquidity Mixes

For unlucky users participating in a final low liquidity mix (e.g. [105d...f55c] or [9035...1c9c]), the expected and actual anonymity set can be off by an order of magnitude.

The report nevertheless labels the claims "High/Critical" and says they cancel earlier privacy.

OXT's follow-up did not repair the missing premise. It argued that a powerful adversary might possess exchange data, pooled surveillance information, or coordinator logs. An adversary might know many things. That does not demonstrate that this attack can acquire the wallet state it requires. My contemporaneous line-by-line response made the distinction: the report assumed near-complete knowledge of the target wallet; its conclusion that prior mixes were "cancelled" did not follow from that assumption; and OXT's own spreadsheet had failed to predict the exact coins selected in its own wallet.^[6]

Adding randomness can be reasonable hardening without validating a claimed exploit. Samourai later treated Wasabi 2's different selection behavior as an admission that OXT had been right.^[7] The timeline disproves that story. We established the Wasabi 2 research effort in January 2020 and publicly presented

WabiSabi in June, before OXT's August disclosure. Wasabi 2 was an already-planned replacement of the CoinJoin protocol and user experience, not a patch accepting OXT's conclusions.^[6]

The contradiction is difficult to miss. OXT's hypothetical Wasabi attacker needed to begin with a target's wallet map. Samurai's real default backend collected wallet maps.

The trap of criminal association

The OXT report was part of a broader tactic. Samurai and OXT repeatedly attached Wasabi's name to alleged criminal activity, then treated the association itself as evidence against us. The trap worked either way. If we answered, we helped spread the association. If we stayed silent, they presented the silence as a concession.

In several instances we never had a safe opportunity to answer. A meaningful response would have required disclosing operational knowledge, investigative methods, or decisions that could not be made public without compromising opsec. Samurai's claims were therefore allowed to circulate largely unchallenged. Their survival online is not proof that they were true. Our silence was not agreement.

I cannot draw a straight causal line from one Samurai post to one institutional decision. I can say what followed: exchanges scrutinized Wasabi CoinJoin deposits, journalists carried the criminal-association narrative outward, and legal and regulatory pressure on the company increased. By 2022, the survival of the company-run coordination service was in question.

The default zkSNACKs coordinator then began rejecting some UTXOs. I had argued against blacklisting, and people who felt betrayed had a legitimate grievance. It was censorship by one service. It was not a mechanism for learning the relationship between accepted inputs and their outputs. The protocol still blinded that relationship; Wasabi remained MIT-licensed; and other coordinators could run without zkSNACKs' policy.^[10]

Samurai converted that policy dispute into the claim that Wasabi had become a surveillance wallet. Meanwhile, Samurai's own default backend received and retained the wallet maps of ordinary users. One system refused some inputs without learning their outputs. The other condemned surveillance while collecting the information needed to perform it.

Adoption did not prove privacy

Whirlpool had users, liquidity, volume, and many remixes. I once treated those measurements as evidence of privacy strength. That was my mistake. Blockchain studies can count transactions and observe user behavior. They cannot measure the wallet graph already known to Samurai's backend through xpubs.^{[11][12]}

Adoption proves that users trusted the promise. It does not prove that the promise was kept.

OXT's report mattered because it gave a marketing attack the appearance of a vulnerability disclosure: a technical PDF, severe labels, a deadline, and claims that users were in immediate danger. Once the premise is examined, the result is much simpler. OXT demonstrated predictable code after giving its observer the information the protocol was designed to hide.

Security claims require precision

The archive contains allegations of wildly different quality. Some are strong. Some are ambiguous. Some were mislabeled before I ever encountered them. A serious account must resist turning them into one undifferentiated charge sheet.

In 2021, an independent researcher disclosed a real local PIN-bypass weakness in Samourai Wallet. Restarting the app reset the attempt counter; wallet metadata required for an offline PIN search was available on the device; and the PIN space was small. The issue became [CVE-2021-36689](#). According to the researcher's timeline, Samourai acknowledged the report and initially decided not to fix it before public disclosure.^[13]

That is a legitimate security failure with a defined version and threat model. It is not evidence that a remote attacker could empty every Samourai wallet.

My *SamouraiLeaks Part 3* investigation concerned a different and earlier codebase: a pre-Samourai Blockchain.info Android application to which William Hill contributed. The repository tied him to a generator that fetched entropy from Random.org over unencrypted HTTP. Under a narrow fallback path on older Android devices, a redirect combined with failed local entropy could produce deterministic key material.^[14] Ars Technica independently reported the conditions and risk in 2015.^[15]

That was a serious historical engineering failure. It was not proof that every Samourai wallet used broken randomness, and it was not proof that William stole anyone's coins.

These qualifications do not weaken my case. They are my case.

Responsible disclosure means defining what happened, who was affected, what is inferred, and what remains unknown. Samourai's communications culture treated those distinctions as weakness when answering critics, then demanded endless qualification when scrutiny turned inward.

The official account made the imbalance visible. It responded to technical and community critics with obscenities, slurs, and personal humiliation.^[16] Vlad Costea described losing followers and being called names after objecting to the bullying. A former r/Bitcoin moderator preserved his allegation that Samourai lied about how it received sidebar placement and free advertising.^[17]



A sample of replies from the official Samourai Wallet account. The language is reproduced because the conduct itself is part of the record.

Any single quarrel can be rationalized. The repeated pattern is harder to dismiss. Intimidation was not a momentary failure of tone. It became part of the product's public identity.

When you wrestle with a pig, you both get dirty

The public record can show a cropped screenshot. It cannot fully show what years of this do to a person.

I began to approach technical conversations as possible trials of character. A bug report might become an allegation that I endangered users deliberately. A journalist's imprecise sentence might become a

confession attributed to me. An audio clip could be cut away from its context and circulated as my position. Silence allowed a false claim to spread. Answering kept the conflict going.

Time I wanted to spend on code went into preserving receipts. Friends and independent developers had to decide whether correcting the record was worth becoming the next target. The most painful part was not being insulted by strangers. It was watching a framework I created get folded into a joint-origin myth, then watching the project that benefited from my premature credit present me as an enemy of privacy.

I did not handle that well.

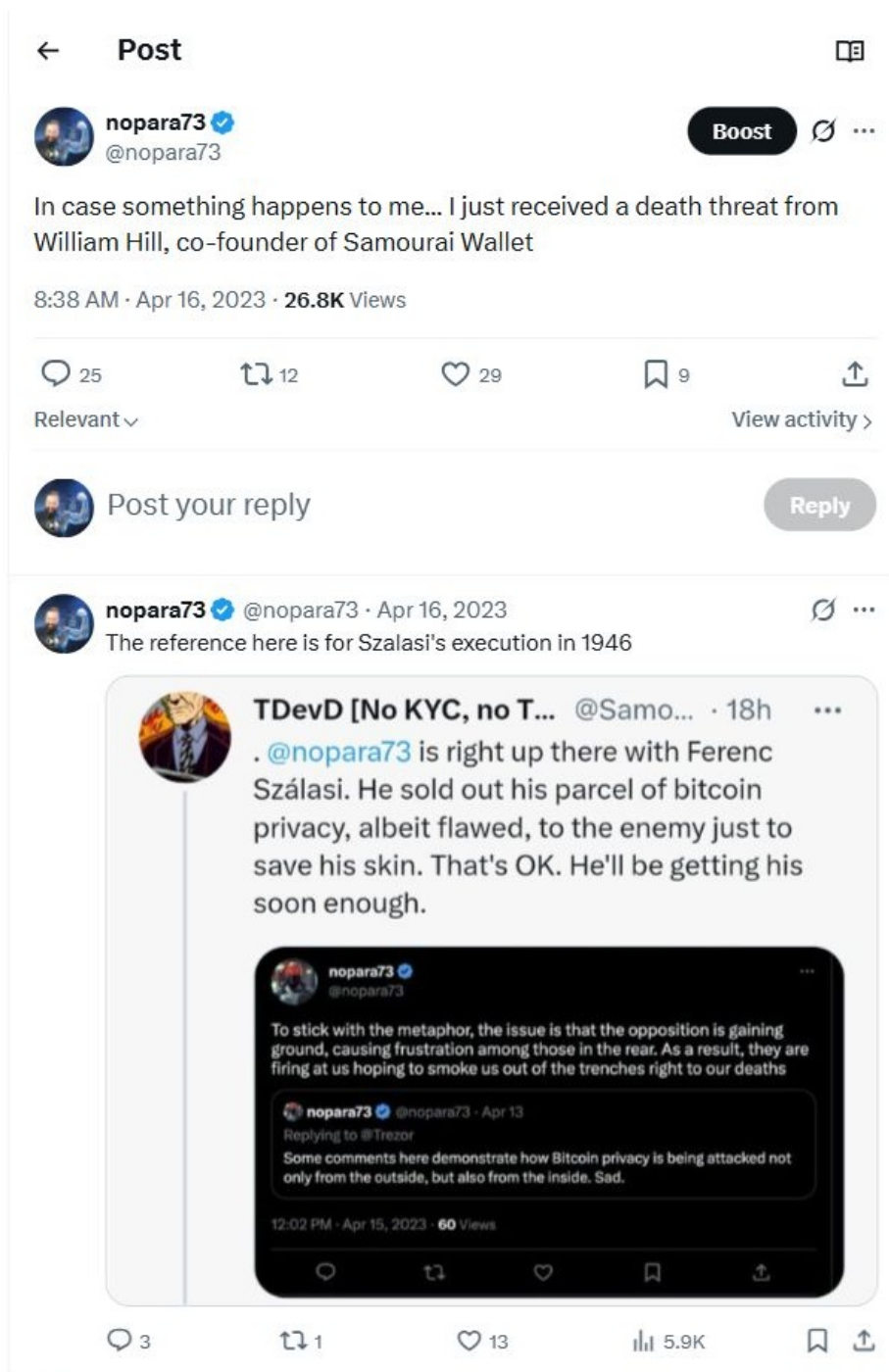
I called the project “Scamourai.” I swore at them. In 2019, CoinDesk quoted one of my replies simply saying “Fuck you.”^[18] The anger was real, but not everything it produced was useful. The nickname was memorable; it was also childish. It allowed a long evidentiary record to be mistaken for reciprocal mudslinging and made it easier for outsiders to conclude that both sides were merely marketing tribes.

I also sometimes spoke with more certainty than the evidence allowed. Receiving an xpub, retaining it, selling it, and maliciously querying it are separate claims. I knew the default backend received wallet-level public information. Before the server analysis became public, I did not know everything Samourai retained or did with it. I should have marked those boundaries in an angry tweet as carefully as I would in a protocol review.

That is my responsibility. It is not an equivalence.

My temper did not write the ZeroLink history. A rude reply did not crop the screenshots. Calling Samourai a name did not cause unrelated developers to report the same retaliation. I can regret the way I fought without pretending there was nothing specific I was fighting.

By April 2023, the conflict had passed far beyond professional hostility. I had received multiple death threats from William Hill - not one. Some were private. Some were public. After another dispute about Whirlpool’s Tor behavior, I wrote: [“In case something happens to me... I just received a death threat from William Hill”](#). I did not publish every message, and what I did publish was only part of what I received.

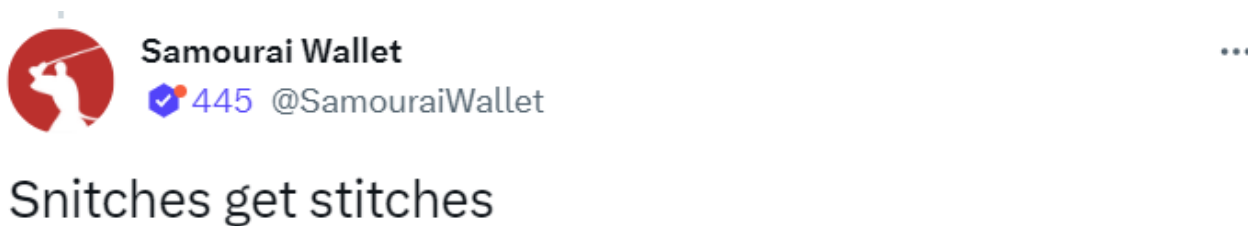


My public statement on April 16, 2023, together with the reference I said I understood as threatening.

The threats were accompanied by doxxing. Hill posted my parents' home address more than once. I will not reproduce or link to those posts, because proving that it happened does not require exposing them again. His public @SamouraiDev profile still names me, says, "It ain't over until the fat boy is gutted," and appends the name of the small town where my parents live.^[threats] There was no technical argument in publishing my family's location beside violent language. It was intimidation.



The public @SamouraiDev profile as preserved on July 10, 2026. I have not reproduced my parents' street address.



The complete source image from the official Samourai Wallet account's "Snitches get stitches" post, preserved in [my contemporaneous X record](#) on April 18, 2023. X's timeline preview cuts off part of the text; this archived source image does not.

The criminal case later produced records independent of the feud.

What the server seizure revealed

When Samurai's founders were arrested in April 2024, I refused to treat the indictment as a verdict. Privacy software is not money laundering merely because criminals use it. The legal boundary around noncustodial software was - and remains - important.

But law enforcement also seized Samurai's servers, and the later filings addressed technical issues I had been raising for years.

In an October 2025 sentencing memorandum, the government said its analysis showed that Rodriguez and Hill had retained enough information to trace or "demix" mobile users' Whirlpool transactions. By cross-referencing stored xpubs with past, present, and future Whirlpool transactions, an analyst could connect the inputs and outputs of many transactions through complex analysis. The filing also stated an important limit: this did not by itself connect those transactions to real-world identities.^[xpub-seizure]

on balance, each defendant is equally deserving of the Stipulated Guidelines Sentence of 60 months.

2. The Defendants Minimize the Scope and Gravity of Their Conduct

Although the defendants admitted in their plea allocutions and plea agreements that they knew criminal drug traffickers and hackers used Samourai to conceal their crime proceeds, the defendants, at several points in their sentencing submissions, minimized their offense conduct and downplayed or outright denied their marketing of Samourai to criminals for money laundering.¹⁶ The defendants make various arguments in this vein. They both emphasize that the main goal of Samourai was to enhance privacy on the Blockchain¹⁷ (Rodriguez Subm. at 2, 7; Rodriguez Letter

¹⁶ Hill concedes, though undersells, his intent for criminals to use Samourai to launder crime proceeds, admitting that “he took things way too far when he . . . actively encouraged its use for money laundering.” (Hill Subm. at 1; *see also* Hill Letter at 3 (“our marketing suggesting that computer hackers and other criminals should use Samourai instead of our main competitor’s wallet spiraled well beyond acceptable limits.”))

¹⁷ Hill claims that he and Rodriguez created Samourai to frustrate Chainalysis and other forensic companies that conducted sophisticated blockchain tracing and wallet attribution because they were “stripping bitcoin of the privacy and fungibility that were the Cypherpunks’ ideals.” (Hill Subm. at 24). The Government notes, however, that Hill and Rodriguez operated OXT.me, a free, public blockchain explorer that was also a tool for blockchain tracing and wallet attribution, including for Silk Road and Hydra Market. (PSR ¶ 38). Thus, it appears that Hill’s animating concern was not fidelity to anonymity, but hostility to forensic companies--like Chainalysis--known to assist law enforcement.

Likewise, notwithstanding Rodriguez and Hill’s strong pro-privacy public comments, they did not always practice what they preached. As confirmed by law enforcement’s seizure and analysis of Samourai’s servers, despite claiming that Samourai was a “privacy” service, Rodriguez and Hill retained sufficient information to trace or “demix” its mobile users’ Whirlpool transactions. In other words, with this information, one could for many Whirlpool transactions, with complex analysis, connect the input and output of a Whirlpool transaction (although this does not deanonymize the transactions). Rodriguez and Hill collected the information by requiring users to share their extended public key (“XPUB”) information with the Coordinator Server. While there was no technical or operational necessity to do so, the defendants chose to retain their mobile users’ XPUB information on Samourai’s servers. This allowed the defendants to cross-reference

36

The government’s description of the server analysis: retained mobile-user xpubs could be cross-referenced with Whirlpool transactions to connect inputs and outputs, without by itself identifying the real-world user. [Open the archived filing.](#)

The defense did not deny xpub collection. Hill’s sentencing submission tried to recast it as a functional necessity: users without their own nodes needed the backend to calculate their balances, it said, and the design affected “only 20%” of Whirlpool users. That was a consequence of Samourai’s chosen architecture, not a universal requirement of light wallets. Wasabi obtained block filters and checked addresses on the client without giving our server the wallet’s xpub.^[operator] The filing also gave no source, methodology, underlying counts, or independent measurement for its percentage. It may have been nothing more than a figure supplied by Samourai and repeated by its lawyers. The submission gives us no way to know.^[xpub-seizure]

Evidence gallery: View the defense's xpub argument and "only 20%" claim

[Case 1:24-cr-00082-DLC](#) [Document 155](#) [Filed 10/24/25](#) [Page 28 of 163](#)

transmitted currency needed to administer the Know-Your-Customer (KYC) and Anti-Money Laundering (AML) controls that, if applied to digital currency, would destroy its peer-to-peer promise. What he came to understand was that other businesses did not have similar obligations, which arose from being deemed a money transmitter. The Financial Crimes Enforcement Network (FinCEN) provided these licenses, so Bill's research focused on their guidance about what constituted a money transmitting business in the context of cryptocurrency. He concluded that it hinged on a binary fact: if a company transmitting cryptocurrency took custody of it, it was a money transmitting business; if it did not, it was not.¹⁸ Bill read this guidance himself, but he also read the commentary around it, which came to the same conclusion he did. As such, when he and Keonne decided to launch a privacy enhancing bitcoin wallet, he built it from the ground up to ensure that it never took custody of its users' bitcoin.¹⁹

F. Samourai Wallet

Samourai Wallet's goal—an easy-to-use mobile app that enabled anonymous transactions that maintained user privacy and therefore enhanced bitcoin's fungibility—was straightforward.²⁰

¹⁸ See, e.g., "Application of FinCEN Regulations to Virtual Currency Mining Operations," FIN 2014-R001, at 3 (Jan. 30, 2014) (explaining that activities that "involve neither 'acceptance' nor 'transmission' of the convertible virtual currency ... are not the transmission of funds within the meaning of the Rule"); "Application of FinCEN's Regulations to Certain Business Models Involving Convertible Virtual Currencies," FIN 2019-G001, at § 4.5.1(b) (May 9, 2019) ("[S]uppliers of tools (communications, hardware, or software) that may be utilized in money transmission, like anonymizing software, are engaged in trade and not money transmission.").

¹⁹ The government aptly explains the mechanics of this process and does not contest Samourai Wallet's non-custodial functioning, so it is not necessary to delve into the technical details. In essence, Samourai Wallet routed communications that permitted parties to a transaction to communicate with each other and engage in the transaction without disclosing their identity or giving Samourai Wallet custody of their bitcoin.

²⁰ Paragraphs 22-23 of the PSR state that Samourai Wallet was not living up to its ideals by collecting certain information on users, suggesting this reveals its stated ideals were subterfuge to cover its true goal of assisting criminals. In fact, the need to collect this "XPUB" data was driven the functional necessity of calculating balances. As with other "light wallets," users who

Building it was not. Single-handedly, Bill wrote the hundreds of thousands of lines of code that powered the app. And like all user-facing software, his job was never done. From 2015 to 2018, he and Keonne ran Samourai Wallet as a money-losing labor of love. After he started working full time on Samourai Wallet, he lived on his saved bitcoin and spent 14-to-16 hours a day, seven days a week at his keyboard. The work consisted of first building and then maintaining the app, as well as developing new features to increase Samourai Wallet's functionality and further its mission.

The two features that led to this prosecution were Ricochet and Whirlpool. As detailed in the indictment, Ricochet built extra "hops" into a Samourai Wallet transaction. The bitcoin still ended up going directly between two transacting parties, but the routing instructions made it appear that other transactions took place in between. The prosecutors are correct that the purpose of Ricochet was to defeat KYC and AML efforts designed to understand who the parties were and whether the transaction was suspicious. But they are wrong as to Bill's motivation. Ricochet, like the rest of Samourai Wallet, was not built to help criminals launder money. It was created to frustrate Chainalysis and the other forensic companies that were stripping bitcoin of the privacy and fungibility that were the Cypherpunks' ideals.²¹ For its part, Whirlpool provided a complex set of communications to effectuate a "Chaumian coin join."²² Effectively creating a new bitcoin

did not have their own bitcoin "nodes"—a computer connected to the blockchain full-time—provided XPUB information to allow the Samourai Wallet app to interact with their wallet via its public key (the "PUB" in XPUB). This affected only 20% of Whirlpool users, and contrary to the PSR's claim, the Samourai Wallet app could not function for this 20% without it.

²¹ Bill conceived of and coded Ricochet after watching a lecture by leading Cypherpunk, Adam Back.

²² The name honors Davis Chaum, an early leader of the Cyberpunk movement who, in 1983, completed his dissertation, "Blind Signatures for Untraceable Payments," the first significant

Hill's sentencing submission described xpub collection as functionally necessary and said it affected "only 20%" of Whirlpool users. The filing supplies no underlying measurement. [Open the archived filing.](#)

"Only" is doing a great deal of work there. So is the unsourced percentage.

Even if the defense's estimate is accepted for the sake of argument, one in five Whirlpool users is a significant part of the user base. More importantly, the argument concedes the architecture I had objected to: a class of users provided its wallet graph to Samourai's infrastructure; Samourai retained that information; and the seizure placed it in government hands. Dojo gave self-hosters a way out. It did nothing for users whose data was already on the default backend.

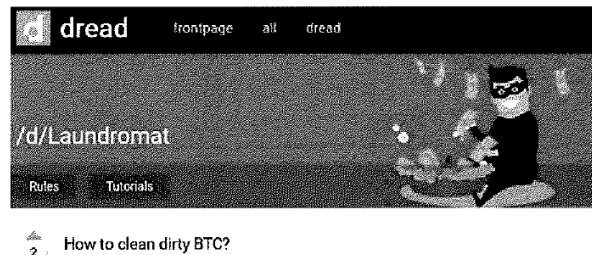
The June 2025 superseding indictment reproduced private messages and Dread posts in which Hill steered people who openly described criminal proceeds away from a competing mixer and toward Whirlpool. It said Rodriguez knew Hill was conducting substantial promotional work on Dread.^[19]

Case 1:24-cr-00082-RMB Document 109 Filed 06/24/25 Page 10 of 29

Samourai's commercial success was driven in large part by such transactions, as over \$250 million in crime proceeds were laundered through Samourai.

20. As one example, on or about January 5, 2018, in a WhatsApp chat, when asked by an associate what "mixing"—*i.e.*, what Samourai did and advertised itself as doing—was, KEONNE RODRIGUEZ, the defendant, described that it was "money laundering for bitcoin." In other words, RODRIGUEZ admitted that the Samourai mixing service was a *money laundering* service, the crime he is charged with conspiring to commit in Count One of this Indictment. Rodriguez's associate then responded with an emoji: "🤖."

21. As another example, on Dread, a Reddit-like dark web message board featuring discussions about darknet marketplaces, WILLIAM LONERGAN HILL, the defendant, expressly advertised Samourai as a money laundering service. As pictured below, the discussion occurred in the subforum titled "Laundromat," bearing the banner photograph of a masked criminal washing money in a bathtub (*i.e.*, laundering or cleaning his dirty money), and in a post titled "How to clean dirty BTC."



In this forum, a Dread user asked what were the most "[s]ecure methods to clean dirty BTC" so that the BTC would become "untraceable, clean" and the Dread user would "never get caught." On or about October 2, 2023, HILL responded by criticizing a competitor mixer ("Mixer-1") by directing the Dread user to "Avoid [Mixer-1] at all costs" and, instead, encouraged the Dread user

to use Samourai, writing that “Samourai Whirlpool is a much better option” to clean dirty BTC—or, in other words, to launder money.

22. In another Dread post, WILLIAM LONERGAN HILL, the defendant, again encouraged darknet marketplace customers to use Samourai to conceal their crimes. In a discussion thread in the subforum “DarkNetMarkets,” titled “Payments on darknet markets,” a Dread user asked why darknet marketplaces still allowed BTC for transactions when “Bitcoin is a well know[n] traceable tool, LE [*i.e.*, law enforcement] have proved it time and time again,” and expressing concern that “people are buying drugs here playing with their freedom.” On or about November 14, 2020, HILL responded by criticizing Mixer-1, directing the Dread user to “avoid[]” Mixer-1 “at all costs,” and, encouraging the Dread user to use Samourai Whirlpool.

23. KEONNE RODRIGUEZ, the defendant, was well aware that WILLIAM LONERGAN HILL, the defendant, advertised Samourai specifically on dark web message boards, including Dread, because on or about August 18, 2020, RODRIGUEZ stated in a Telegram thread with an associate that “we’re making a space on the dark net boards, dread in particular” and HILL “has been doin[g] a lot of work there.”

24. In private Telegram messages with an associate, KEONNE RODRIGUEZ, the defendant, made clear that he intended for criminals to use Samourai to conceal their crime proceeds and that he believed that Samourai’s competitor, Mixer-1, inadequately concealed crime proceeds, which likely would result in incarceration. For example, on or about July 27, 2019, RODRIGUEZ wrote that Mixer-1 was “playing fast and loose” with its concealment methodology, and “is likely to get someone locked up.” RODRIGUEZ’s associate replied, “[e]specially as some of the people that have BTC from obvious hacks etc haven’t mixed them in a sophisticated way.” RODRIGUEZ endorsed the message by responding, “yeah it is crazy.”

Pages 10 - 11 of the superseding indictment reproduce the Dread context and allege that Hill steered users describing criminal proceeds toward Whirlpool, while Rodriguez knew he was doing promotional work there. An indictment is an allegation, not a verdict; both men later entered guilty pleas to the offense described below. [Open the archived indictment.](#)

This mattered because Samourai and OXT had repeatedly turned criminal use of Wasabi into part of the public case against us. Yet the later record showed Samourai pursuing those same users as customers. On Dread, competitor disparagement was not an abstract contribution to privacy research. It was a sales pitch aimed at people asking how to conceal criminal proceeds.

In August 2025, Rodriguez and Hill each pleaded guilty to conspiring to operate a money-transmitting business knowing it transmitted crime proceeds. The money-laundering conspiracy count was dropped

through the plea agreements. The Justice Department’s account of the pleas included their Dread marketing.^[21] In November, Rodriguez received five years in prison and Hill four.^[22]

I do not celebrate those sentences as the resolution of a software feud. Nor will I pretend the prosecution raised no troubling issues. Before the pleas, the defense argued that prosecutors had disclosed too late a FinCEN communication saying Samourai’s lack of control over users’ keys strongly suggested it was not a money-services business under FinCEN’s rules. The government disputed the communication’s significance.^[23] Anyone who cares about open-source privacy software should care about that due-process issue.

The state did not vindicate me. Prison cannot restore authorship, repair a community, or prove a protocol sound. What the case added was evidence about retention, intent, and marketing that had not been public when the feud began.

The lies and hypocrisies

Not every mistake is a lie. Developers can be wrong. Memories can diverge. Certainty can come from arrogance rather than conscious deception. A lie requires something more: a materially false account preserved after contrary evidence has been presented because the false version remains useful.

By that standard, the ZeroLink co-creation story was a lie. The framework predated Samourai’s involvement; the first Samourai contribution fixed typos; and they repeated the joint-origin account years after I challenged it with the repository.^{[zerolink][7]}

The claim that I had admitted Wasabi supplied its own liquidity was false. The journalist corrected that interpretation, but Samourai continued promoting the damaging version while omitting my correction.

The categorical Tor answer was a falsehood. The public evidence cannot tell us whether Rodriguez knowingly lied or answered with reckless certainty. It can tell us that he insulted the questioner and that the code later added the very identity change the question had asked about.^[5]

The deepest deception concerned the privacy promise itself. Samourai marketed resistance to financial surveillance while the default wallet sent xpubs to its hosted backend and left Tor off unless the user enabled it. The hosted service could therefore receive the wallet graph and the connecting IP address together. They also called Sentinel the “easiest and most secure” way to watch cold storage, while its hosted-server mode handed Samourai the xpub that allowed Samourai to watch it too. When the wallet’s unsafe defaults were reported on Samourai’s GitLab, the project owner rejected the proposed change, threatened the reporter, and closed the issue. The server seizure later demonstrated why the backend’s wallet-level information mattered.^{[operator][tor-default][sentinel][xpub-seizure]}

The most direct hypocrisy concerned criminal association. Samourai repeatedly tried to turn alleged criminal use of Wasabi into a case against us while privately promoting Whirlpool to darknet users who openly described criminal proceeds.^{[19][21]}

Even the blacklisting dispute contained this reversal. Criticism of zkSNACKs’ policy was fair. Calling Wasabi a surveillance wallet while Samourai retained xpub-derived wallet graphs was not. Wasabi’s policy determined which inputs one coordinator would accept, but its blinded design still prevented the operator from linking those inputs to their outputs. Samourai’s default backend retained wallet-level information.^{[operator][10][xpub-seizure]}

That is why I call it Scamourai.

I do not mean “fraud” as a legal count. I mean that the product’s central promise was false in ordinary language. It sold protection from surveillance while placing its operator in a position to surveil. It promoted verification while requiring default users to trust that Samourai would not misuse wallet information that its servers retained.

That was not merely imperfect privacy. The hypocrisy was built into the default architecture.

Post-mortem

What did Samourai take from me?

Not my ability to write code. Not Wasabi’s existence. Not the Git record.

It took clarity of authorship. I gave TDevD more credit than the record justified, and Samourai inflated that gift into co-creation. Adoption became invention. Minor edits became joint research. Repetition turned a useful falsehood into public memory.

It also took years in which two projects could have competed while still teaching users the truth about their threat models. Samourai made correction look like surrender, uncertainty look like weakness, and disagreement look like disloyalty. It made cooperation difficult and turned technical competition into personal hostility.

I helped that transformation when I answered contempt with contempt. I cannot recover those years or unsay those words. What I can do is leave a record more careful than the fight itself.

The lesson I want future privacy developers to take is not “trust nopara73.” It is not “never trust a server,” “never trust a coordinator,” or “my CoinJoin was the good one.” It is this:

Do not treat a team identity or a founder’s character as a privacy guarantee. When a critic finds a bug, examine it before attacking the critic. When the evidence is uncertain, say so. When the code changes, correct the old claim as publicly as you made it. When a competitor is right, acknowledge it.

Most of all, judge a privacy system by what an adversary can obtain if the operator is compromised, coerced, or captured. The protocol should protect users even if the operator’s servers are seized.

Sources and notes

- [zerolink]** The figures in this section were reproduced from the [ZeroLink repository](#) using the full commit graph, non-merge README.md numstats, and line-porcelain blame at commit [25d1502](#), the August 14 publication snapshot used for the audit. The 13 Bill/TDevD commits comprise 97 additions and 43 deletions; nopara73's 134 non-merge commits comprise 1,151 additions and 684 deletions. Line churn is not equivalent to intellectual authorship, which is why the chronology and individual patches are also described.
- [operator]** Wasabi's documentation explains its [block-filter and Tor architecture](#), including why sending an xpub to a central server enables complete wallet deanonymization, and states that its [coordinator cannot link inputs to outputs](#). Samourai's archived [Dojo documentation](#) says MyDojo bypasses the default hosted servers and describes a Tracker that records the activity of registered xpubs and addresses. The inference about mixed Dojo/default-server rounds is also explained by Chris Belcher and the independent thesis cited in note 1.
- [tor-default]** Samourai's signed Android source at commit [`c71f21a`](#) (v0.99.95, June 17, 2020) provides direct evidence of the defaults. [`LandingActivity.java`](#) permits wallet creation independently of the Tor switch and reads `ENABLE_TOR` with a `false` fallback. [`SamouraiApplication.java`](#) starts Tor only when that preference is true. [`APIFactory.java`](#) sends xpub queries through the ordinary `postURL` path when Tor is not required, and its [xpub-registration method](#) makes the same direct/Tor distinction. The archived April 17, 2023 [GitLab issue #458](#) preserves the screenshot of Tor off and Dojo unconfigured, the proposed safer defaults, the project owner's response, and the immediate closure. Samourai's own 2021 account described Tor as something users could activate [with a button](#); contemporary setup guides likewise instructed users to enable it.
- [sentinel]** Sentinel's own [welcome text](#) called it the "easiest and most secure" way to watch cold storage and emphasized that private keys were never communicated to the app; that statement addressed custody, not xpub privacy. The official repository shows the relevant history directly. On August 12, 2017, commit [`77eca1d`](#) changed the xpub `multiaddr` request from Blockchain.info to Samourai's API. Commit [`1a4722f`](#), dated September 20, 2019, added Tor routing and a network dashboard. In the ensuing v3.6 source, [`APIFactory.java`](#) sends each xpub as `multiaddr?active=<xpub>`; [`InsertSegwitActivity.java`](#) separately posts the imported xpub to the `/xpub/` endpoint; and [`WebUtil.java`](#) reads the Tor preference with a `false` fallback, while its [API selector](#) uses the public Samourai endpoint when Tor is not required. A mirror preserving the last pre-seizure GitLab history shows the same design in v5: the first-run screen offered [Samourai's server and a separate yes/no Tor prompt](#), while [`ApiService.kt`](#) posted the imported xpub to `/xpub`. RoninDojo's contemporary [v5 guide](#) independently describes the choice between the user's Dojo and Samourai's node.
- [threats]** My [April 16, 2023 public statement](#) records one of the threats. Hill's public [`@SamouraiDev` profile](#), checked July 10, 2026, names me, uses the quoted "guttled" language, and appends my parents' town. Current social-media index caches independently reproduce the same profile text, including [this TwStalker index](#) and [this second index](#). My parents' street address is intentionally neither reproduced nor linked.
- [1]** Denis Varga, [*CoinJoin Protocols and Implementations Analysis*](#), Masaryk University master's thesis, 2022, especially pp. 58 - 70. The thesis found that Whirlpool closely followed its detailed specification, described Wasabi 1's specification as outdated relative to its implementation, and emphasized the privacy trust placed in Samourai's default backend. See also Greg Maxwell's [2018 architectural criticism](#) and Chris Belcher's explanation of the [mixed Dojo/default-server anonymity set](#).
- [2]** ZmnSCPjx, [Reddit comment](#), January 2021. He said Samourai had misconstrued his "pure ZeroLink" comment and distinguished using the default backend from running one's own node and software.
- [3]** *Citadel Dispatch*, ["JoinMarket Dev: Wasabi vs Samourai"](#), December 2022, especially 11:24 - 19:43. The relevant clip was also [posted to Reddit](#).
- [4]** BlockDigest, [SHI256 episode 256](#), especially 57:42 - 64:10, discussing PayNym short-name caching, the response to questions, and the later patch.
- [5]** [Screenshots of the April 2023 Telegram exchange](#). The gallery preserves Rodriguez's categorical answer and the surrounding dispute. The later code commit is linked in the body.
- [6]** OXT's archived [full technical report](#) supplies the details omitted from its public warning. On pp. 2 - 3 it requires knowledge of the target wallet's composition at step N and knowledge of subsequent mixing events. On pp. 5 - 7 its test gives "Eve" knowledge of "Alice's" funds and wallet state, starts Alice with a single known 0.4 BTC input, and uses a modified client to log round events. The report's "vulnerability #2," on pp. 4 - 5, uses change-output "beacons and checkpoints" to detect deviations from the first model. The resulting "adjusted anonsets" are OXT's analytical estimates; the test does not identify Alice as a real person or recover a blinded input-output mapping. OXT's [initial warning](#) demanded a public statement within forty-eight hours and labeled the claims Critical. My [contemporaneous line-by-line response](#) identifies the assumed wallet knowledge, the unsupported leap to "cancelling" previous mixes, and OXT's failed predictions in its own spreadsheet. OXT's [follow-up](#) answers

the missing-knowledge objection by hypothesizing powerful adversaries with pooled data and coordinator logs, but does not demonstrate how its tested observer acquired the target wallet state. The claim that Wasabi 2 was a response is also contradicted by the public timeline: Bitcoin Optech covered WabiSabi on [June 17, 2020](#), and the Wasabi 2 [status report](#) says the research team was established in January 2020 - both before OXT's August disclosure.

- [7] Bitcoin Takeover, [interview with Samourai Wallet](#), June 2022, especially 15:20 - 18:58. The interview repeats Samourai's joint-origin account of ZeroLink and presents Wasabi 2's later selection behavior as confirmation that OXT's criticism forced a fix. The ZeroLink repository does not support co-creation, while the WabiSabi timeline in note 6 predates OXT's disclosure.
- [10] The original March 2022 announcement is quoted in [contemporaneous coverage](#). zkSNACKs later explained in this [open discussion](#) that the company was under legal and regulatory pressure, did not want to perform its own surveillance, and expected alternative coordinators to remain possible. The operational pressure described in the body is my first-person recollection; the linked public sources corroborate the general context, not every internal detail.
- [11] Florian Matzutt et al., "[Adoption and Actual Privacy of Decentralized CoinJoin Implementations in Bitcoin](#)", AFT 2022. The authors detected 30,251 Wasabi and 223,597 Samourai transactions through February 2022 using heuristics they report as more than 99 percent accurate. Their observations concern on-chain patterns and user behavior; they cannot measure the Samourai operator's off-chain knowledge from xpubs.
- [12] Lucianna Kiffer et al., "[CoinJoin Ecosystem Insights for Wasabi 1.x, Wasabi 2.x and Whirlpool Coordinator-Based Privacy Mixers](#)", *Proceedings on Privacy Enhancing Technologies*, 2026. The paper measures adoption and liquidity; it expressly does not provide a full deanonymization-resilience comparison.
- [13] Justin Steven, "[Samourai Wallet Bitcoin PIN Authentication Bypass](#)", August 2021. The post contains the technical report, proof of concept, affected version, and disclosure timeline.
- [14] My article, "[SamouraiLeaks Part 3: Is random.org Random Enough?](#)", July 2019; the historical ``RandomOrgGenerator.java``. Repository history attributes the relevant 2014 commit to William Hill.
- [15] Dan Goodin, "[Crypto Flaws in Blockchain Android App Sent Bitcoins to the Wrong Address](#)", *Ars Technica*, May 2015; original [technical discussion](#).
- [16] [Gallery of posts from the official Samourai account](#); one surviving [March 2021 post](#). The purpose of citing these is to document tone and targeting, not to endorse repeating the slurs.
- [17] Vlad Costea, [post about the reaction to criticizing Samourai](#), August 2020; BashCo, [archived post about the r/Bitcoin promotion dispute](#), August 2020.
- [18] Leigh Cuen, "[A Battle Between Bitcoin Wallets Has Big Implications for Privacy](#)", *CoinDesk*, August 2019. The article is a useful contemporary record of the dispute, but its competitive framing should be read against the default xpub asymmetry documented above.
- [xpub-seizure] The U.S. Attorney's Office said that Icelandic authorities [seized Samourai's web servers and domain](#) on April 24, 2024. The government's later [sentencing memorandum](#), *United States v. Rodriguez and Hill*, No. 1:24-cr-00082-DLC, ECF No. 157 (S.D.N.Y. Oct. 31, 2025), pp. 36 - 37, says server analysis showed retained xpub data could be used, through complex analysis, to associate inputs and outputs for many mobile users' Whirlpool transactions; it also reproduces Hill's post-seizure messages about the "wallet backends (xpubs)." Hill's own [sentencing submission](#), ECF No. 155 (S.D.N.Y. Oct. 24, 2025), pp. 23 - 24 & n.20, argues that xpub collection was necessary for light-wallet balance calculation and asserts that it affected 20 percent of Whirlpool users. The submission provides no citation, methodology, underlying counts, or independent study for that percentage, and the government's memorandum does not validate it. The government's "demix" finding is itself a representation in a sentencing memorandum, not an independently published forensic report.
- [19] *United States v. Rodriguez and Hill*, [Superseding Indictment](#), No. 1:24-cr-00082-RMB, ECF No. 109 (S.D.N.Y. June 24, 2025), especially pp. 10 - 16. These passages were allegations at the time of filing; later admissions are separately cited below.
- [21] U.S. Attorney's Office, Southern District of New York, "[Founders of Samourai Wallet Cryptocurrency Mixing Service Plead Guilty](#)", August 6, 2025. For the plea bargain's dismissal of the laundering count, see [contemporaneous reporting](#).
- [22] U.S. Attorney's Office, Southern District of New York, "[Founders of Samourai Wallet Cryptocurrency Mixing Service Sentenced to Five and Four Years in Prison](#)", November 19, 2025.
- [23] Defense letter alleging late disclosure of FinCEN communications, [*United States v. Rodriguez and Hill*](#), May 5, 2025. This was a defense argument, not a judicial finding.

Further reading

- BlockDigest, [SHI256 episode 1](#), July 2019. Shinobi distinguishes the architectures and records the contemporary “two competing approaches” view; that framing does not negate the default xpub disclosure.
- Yuval Kogman, [“Unbreaking Whirlpool’s Privacy”](#), Bitcoin Development Mailing List, December 2024. Kogman discloses his connection to WabiSabi and analyzes a coordinator key-consistency problem affecting both protocol families; he states that he found no evidence the Whirlpool coordinator had exploited it.
- WalletScrutiny, [historical reproducibility record for Samourai Wallet](#). Results varied by release and build conditions; the current seizure-era status should not be projected backward onto every version.
- nopara73, [*ScamouraiWallet* source archive](#). The archive preserves useful leads but contains mislabeled links; this essay relies on the underlying sources rather than treating the repository’s labels as evidence.